

AI Candidate Sourcing Platform

Everything a new team member or owner needs to know: what the system does, who can do what, every page and button, how the AI sourcing pipeline works, and where its limits are.

Admin

HR Manager

HR User

Next.js + Supabase

OpenAI + SerpApi + Apify

Contents

- 1 What the system is and who it is for
- 2 The three roles at a glance and the permission matrix
- 3 System architecture and tech stack
- 4 Getting in: sign-up, invites, access requests, deactivation
- 5 Navigation and shared parts (menu, notification bell, toasts, settings)
- 6 Page-by-page tour with button reference
- 7 The AI sourcing pipeline end to end
- 8 Ownership, access tracking and read-only viewing
- 9 Reports and exports
- 10 Activity log and audit trail
- 11 Data model
- 12 Security model and error responses
- 13 Common workflows, step by step
- 14 Known limitations and gotchas
- 15 Glossary

Wireframes in this guide are illustrative HTML/CSS mockups of the app screens, not screenshots. Facts were verified against the source code and the live database schema.

1. What the system is and who it is for

A web application that helps recruiters find candidates in Egypt. You upload or paste a job description, AI turns it into structured requirements, the system searches public sources for matching people, and AI scores each person against the role.

1. Describe the role

Upload a PDF/DOCX/TXT or paste text. AI extracts title, skills, seniority, education and more. You review and edit them.

2. Find people

AI writes Google X-ray search queries. SerpApi runs them, Apify enriches LinkedIn profiles, and only candidates located in Egypt are kept.

3. Score and decide

On demand, AI scores every candidate 0-100 against the job. Recruiters set statuses, add notes and export to Excel.

Who uses it

Person	What they do in the system
HR User	The recruiter. Creates jobs, runs sourcing searches, scores and manages candidates. Sees only their own work.
HR Manager	Leads a team of HR Users. Does everything an HR User does for their own work, plus a read-only view of the team: performance, sourcing files, candidates and activity. Gets notifications about team activity.
Admin	Runs the organization. Invites and approves people, creates teams, assigns roles and managers, deactivates access, sees organization-wide performance and all reports. Also read-only on other people's sourcing data.

Key ideas to remember

- **Access is by invitation.** Signing up is not enough. An account only works when an admin has invited or approved it (section 4).
- **Data has one owner.** Whoever creates a job owns it and everything found for it. Nobody else can edit it, not even an admin. Managers and admins can only *look* (sections 2 and 8).
- **Searching and scoring are separate steps.** A search finds candidates but does not score them. Scoring is a manual click on the candidates page (section 7).
- **Everything is recorded.** Important actions go into an append-only activity log that feeds notifications and reports (section 10).
- **Egypt only.** Every job is located in Egypt; the optional city narrows the search to Cairo, Alexandria, Giza or Suez.

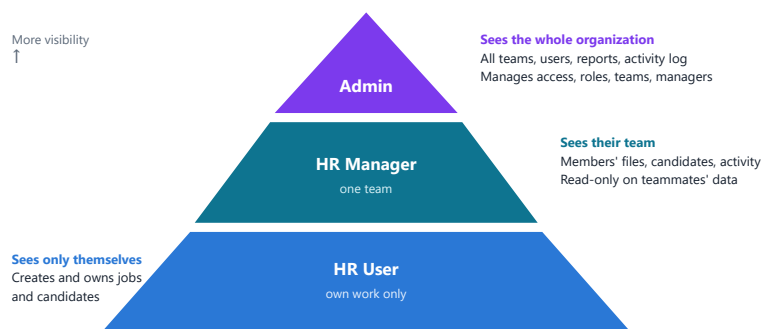
Vocabulary used throughout

Job = a role you are hiring for. **Sourcing run** (also called a **sourcing file**) = one execution of a search for a job.

Candidate = a person found. **Match score** = AI's 0-100 fit rating of a candidate for a specific job. See the Glossary in section 15.

2. The three roles at a glance

Roles form a hierarchy of **visibility**, but not of **ownership**. Going up the tiers you can see more, yet you can never edit another person's jobs or candidates.



Visibility grows upward. Ownership never moves: every write is owner-only at every tier.

Admin

Default landing: `/dashboard` (personal). Extra pages: `/admin`, `/manager` (any team), org-wide `/reports`. Bell: access requests only.

HR Manager

Extra page: `/manager` pinned to their own team. Team-scoped reports. Bell: team sourcing runs, shortlists, hires, strong matches.

HR User

Base pages only: Dashboard, Jobs, Candidates, Reports (own work), Settings. No bell, no Team or Admin links. Visiting `/manager` or `/admin` bounces to the dashboard.

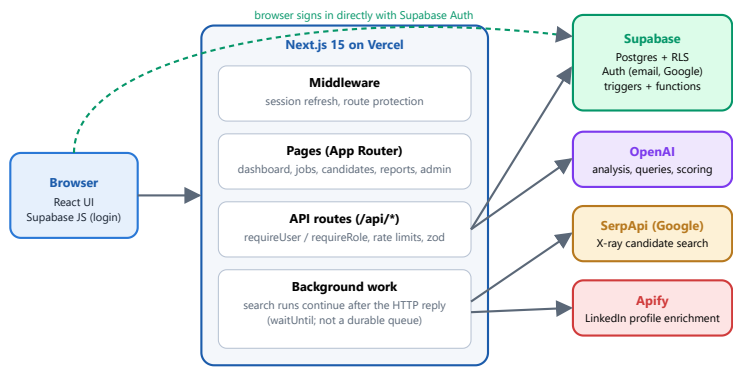
Permission matrix

Nobody can edit or delete activity log entries. Green = allowed, amber = read-only (can look, cannot change), red = not allowed. "Own" means data the person created themselves.

Capability	Admin	HR Manager	HR User
Create, search, score, delete own jobs and candidates	Yes	Yes	Yes
Change status / add notes on own candidates	Yes	Yes	Yes
Personal dashboard, Jobs list, Candidates picker (own only)	Yes	Yes	Yes
Open a teammate's job / sourcing file / candidate	Read-only, anyone	Read-only, own team	No
Edit, delete, re-score, re-search or add notes on someone else's data	No	No	No
Export Excel of a job's candidates	Any job they can open	Own + team jobs	Own
Team dashboard <code>/manager</code> and member pages	Any team	Own team	No
Reports (4 types, CSV/Excel)	Whole org or one team	Own team	My work only
Notification bell	Access requests	Team activity	No bell
See team activity log entries	All	Own team	Own only
Admin dashboard <code>/admin</code>	Yes	No	No
Invite people, approve access requests, withdraw invites	Yes	No	No
Change roles, teams; deactivate / reactivate users	Yes (not self)	No	No
Create teams, assign a team manager (no rename/delete in the UI)	Yes	No	No

3. System architecture and tech stack

The app is a single Next.js project deployed on Vercel. The browser talks to Next.js pages and API routes; API routes talk to Supabase (database, login) and to three outside services.



Solid arrows: server-side calls made by API routes. Dashed arrow: the browser logs in directly against Supabase Auth.

Tech stack

Layer	Technology
Framework	Next.js 15 (App Router), React 19, TypeScript 5.7, Node 20.16+
UI	Tailwind CSS 3, Radix primitives, shadcn-style components, lucide icons, fonts Inter and Fraunces
Database and auth	Supabase (Postgres 17, region eu-central-1, project "ai-candidate-sourcing"): Row Level Security on all 16 public tables, email/password and Google sign-in
AI	OpenAI only (default model <code>gpt-5.6-luna</code> , overridable by <code>OPENAI_MODEL</code>); no temperature is sent because the model rejects it
Search	SerpApi (Google) via <code>SEARCH_PROVIDER=serpapi</code> ; <code>mock</code> returns 8 fixture candidates (the default when unset); <code>serper</code> is declared but not implemented
Enrichment	Apify LinkedIn profile scraper (optional; needs <code>APIFY_API_TOKEN</code> and <code>APIFY_ACTOR_ID</code> together)
Files and export	<code>pdf-parse</code> and <code>mammoth</code> extract job description text; SheetJS <code>xlsx</code> writes Excel
Validation	zod 4 on every API body; environment variables validated at boot
Hosting	Vercel; structured JSON logs with an <code>x-request-id</code> on every response
Tests	Vitest, Testing Library, Playwright

Required and optional configuration

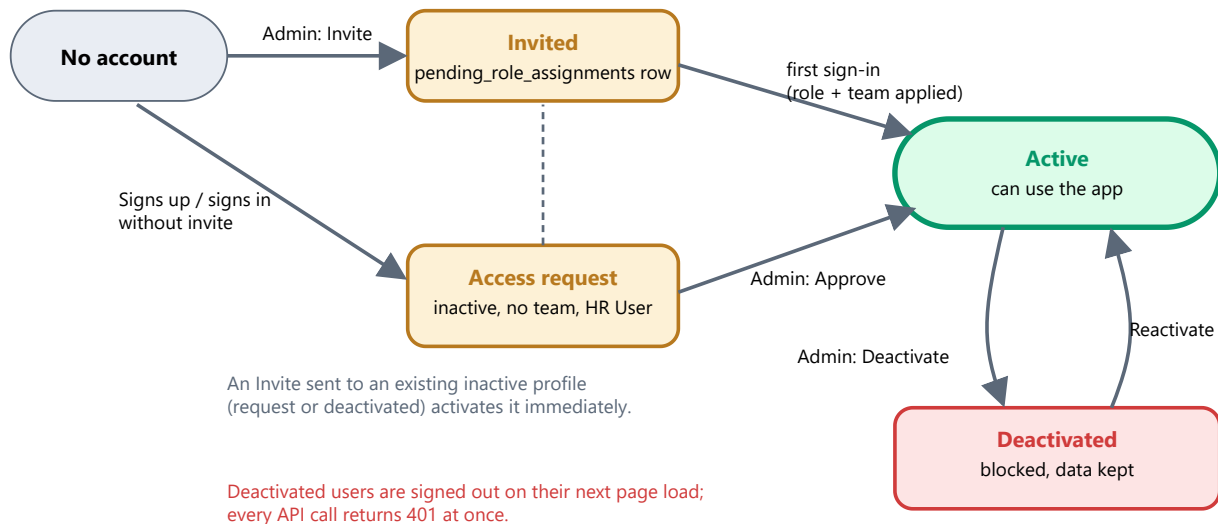
Variable	Purpose
<code>NEXT_PUBLIC_SUPABASE_URL</code> , <code>NEXT_PUBLIC_SUPABASE_ANON_KEY</code> , <code>SUPABASE_SERVICE_ROLE_KEY</code>	Required. The app refuses to start if missing or invalid.
<code>SEARCH_PROVIDER</code>	<code>mock</code> (default), <code>serpapi</code> , <code>serper</code> .
<code>OPENAI_API_KEY</code> , <code>OPENAI_MODEL</code>	AI features. Without a key, AI calls fail with a 500.
<code>SERPAPI_API_KEY</code> , <code>SERPER_API_KEY</code>	Search provider keys.
<code>APIFY_API_TOKEN</code> , <code>APIFY_ACTOR_ID</code>	LinkedIn enrichment; set both or neither.

Tip: if `SEARCH_PROVIDER` is left at its default `mock`, searches return the same 8 fixture people instead of real results.

4. Getting in: accounts and access

Nobody can use the app just by creating an account. Access equals an **active profile** in the database. An admin grants it either *before* the person signs in (an invite) or *after* (approving an access request).

Account lifecycle



Account states. There is no "rejected" state: an unapproved request simply stays in the list.

Path A: invited first

- 1 Admin enters email, role and team on `/admin` and clicks Invite.
- 2 The system stores a pending invite. **No email is sent**; tell the person yourself.
- 3 The person signs up (email or Google) using that exact email.
- 4 A database trigger creates an **active** profile with the invited role and team, and removes the invite.

Path B: request first

- 1 Someone signs up or signs in with Google without an invite.
- 2 An inactive profile is created; they are signed out with "not_allowed".
- 3 All admins get a bell notification linking to `/admin`.
- 4 Admin picks role and team and clicks Approve. The person can now sign in.

Edge case

An access request is recognised as "inactive + no team + role HR User". A deactivated HR User who has no team looks identical, so they appear under Access requests instead of User Management.

The login screen (/login)

app / login

1

2

3

4

5

Log in

Enter your email and password to continue.

Email

Password

Log in

or

Continue with Google

Need an account? Sign up

- 1 Email field (required, must be a valid email).
- 2 Password field (required, at least 6 characters).
- 3 Main submit button; reads "Log in" or "Sign up" depending on mode, and "Please wait..." while working.
- 4 "Continue with Google" (Google OAuth).
- 5 Mode switch link between Log in and Sign up.

Control	What it does	API / route	Notes
Log in	Signs in with email and password. On success sends a "login" audit event and goes to / , which forwards to /dashboard .	Supabase <code>signInWithPassword</code> ; POST <code>/api/auth/events</code>	Wrong credentials show the error text and record a "failed sign-in" (only for real accounts, max 10 per account per hour). The <code>redirectTo</code> parameter from a blocked page is not used by this flow.
Sign up	Creates an account. Message: "Account created. Check your email to confirm, then log in. If you weren't invited, an admin will need to approve your access first."	Supabase <code>signUp</code>	Does not log you in. Uninvited sign-ups become access requests.
Continue with Google	Redirects to Google, then back to <code>/auth/callback</code> . Label becomes "Redirecting..." while pending.	<code>signInWithOAuth</code> ; GET <code>/auth/callback</code>	Callback rejects users without an active profile (signs them out, sends to <code>/login?error=not_allowed</code>). On success logs "Signed in with Google" and lands on <code>/dashboard</code> .
Need an account? Sign up / Already have an account? Log in	Toggles the card between the two modes and clears messages.	none (client only)	

Messages you may see on the login page

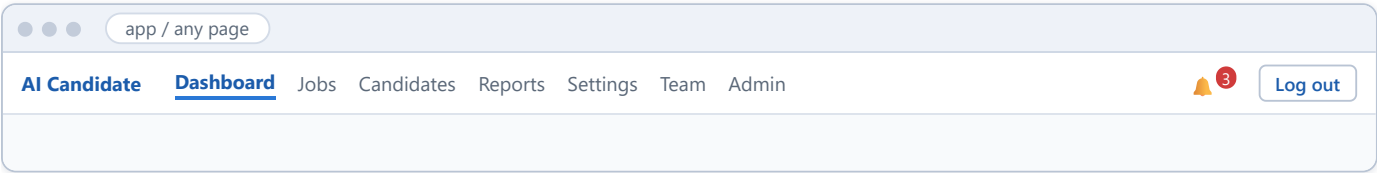
Trigger	Text
?error=not_allowed	"Your account doesn't have access yet. Ask an admin to invite you or approve your access request."
?error=oauth_failed	"Google sign-in failed. Please try again."
Wrong password	The Supabase error message, in red.

Deactivation

An admin clicks **Deactivate** on `/admin`. The person keeps all their data, but immediately every API call returns 401, and at their next page load they are signed out with the "not_allowed" message. Any elevated database powers (admin or manager visibility) also stop at once. If they were a team's manager, the team becomes "Unassigned". Reactivating restores access; an HR Manager with a team is re-attached as manager only if that team currently has none.

5. Navigation and shared parts

Top menu by role



Menu item	Admin	HR Manager	HR User
Brand "AI Candidate" (goes to /dashboard)	Yes	Yes	Yes
Dashboard, Jobs, Candidates, Reports, Settings	Yes	Yes	Yes
Team (/manager)	Yes	Yes	No
Admin (/admin)	Yes	No	No
Notification bell	Yes	Yes	No
Log out button	Yes	Yes	Yes

The role is read by the browser (a database call) and only decides which links to show. Until it loads, only the five base links appear. Every page and API re-checks the role on the server, so hiding a link is cosmetic, not security. "Dashboard" is active only on the exact path; other links stay active on sub-pages.

Notification bell

Only Admins and HR Managers have a bell. It shows an unread count (99+ cap) and refreshes every 60 seconds while the tab is visible, when the tab regains focus, and when opened. The list holds the 20 latest items. Clicking an item marks it read and opens its destination.

Control	What it does	API / route	Notes
Bell icon	Opens or closes the "Notifications" panel and refreshes it.	GET /api/notifications	Closes on Escape or outside click.
Mark all as read	Marks every unread item read. Only shown when something is unread.	PATCH /api/notifications (empty body)	Optimistic update.
Notification row	Marks that item read and navigates to its target.	PATCH /api/notifications {ids}	Unread rows have a dot and tinted background.

Every notification type

Event	Who is notified	Text (after the actor's name)	Opens
Someone requests access	All active admins	requested access to the app	/admin

Event	Who is notified	Text (after the actor's name)	Opens
Sourcing run started	Active HR Manager(s) of the actor's team , never the actor	started a sourcing run for "Job"	<code>/candidates?</code>
Sourcing run completed		completed a sourcing run for "Job" (N candidates, M new)	<code>jobId=&runId=</code> (read-only view, records an access)
Sourcing run failed		had a sourcing run fail for "Job"	
Candidate set to Shortlisted or Hired		changed Name's status from X to Y	<code>/candidates/<id></code>
Candidates scored with at least one strong match		scored N candidates for "Job" - K strong match(es) (80%+)	<code>/candidates?jobId=</code>
Other notification targets fall back to the actor's page <code>/manager/team/<userId></code> .			

What does NOT notify

File opens, job creation or edits, notes, status changes to Reviewed / Contacted / Rejected, sign-ins, a manager's own actions, and anything for a person without a team. Admins are notified only about access requests, not team activity. There are no emails or push messages anywhere in the system.

Toasts, errors and loading

- **Toasts** appear top-right for 4 seconds in four colours (success, error, warning, info) and each has a close button. They confirm saves and report failures.
- **Something went wrong** page: shown for unexpected errors, with a [Try again](#) button.
- **Page not found** page with a [Back to dashboard](#) link. Also used when you open a team member outside your team.
- **Skeleton loaders** (grey pulsing blocks) appear while Dashboard, Admin, Team, Reports and Settings load.

Settings (/settings) and logging out

Settings is open to every role and contains one card, "Account", showing "Signed in as <your email>". There are no editable controls: no password change, profile or preferences.

Log out (outline button in the menu, no confirmation): records a "Signed out" audit event, ends the session and returns to [/login](#).

6. Page-by-page tour

Each page below shows who can open it, a wireframe with numbered callouts, and a reference table of every button, dropdown, filter and link. Wireframes are illustrative mockups, not screenshots.

Route	Purpose	Who
/login	Sign in / sign up	Everyone
/dashboard	Personal sourcing overview	Admin Manager User
/jobs , /jobs/new	Your jobs; create a job and start sourcing	Admin Manager User
/candidates , /candidates/[id]	Pick a job, review and score candidates; candidate profile	Admin Manager User (others' files: read-only, Admin/Manager only)
/reports	Four reports with CSV/Excel export	Admin Manager User (different scopes)
/settings	Shows your account email	Everyone
/manager , /manager/team/[userId]	Team dashboard, member drill-down	Admin Manager
/admin	Organization dashboard, access and team management	Admin

/login

Login

public

Fully covered in section 4 (wireframe, every button, messages). If you are already signed in, / sends you to /dashboard ; a signed-out visitor to any protected page is sent here.

/dashboard

Dashboard

Admin

Manager

User

A **personal** dashboard, identical for all roles: every number covers only jobs and candidates *you* own. Team and organization views live on /manager and /admin . There are no filters or date ranges.

app / dashboard

AI Candidate DashboardJobsCandidatesReportsSettingsLog out

Candidate Sourcing Hub

AI-Powered Recruitment Pipeline

New Job OpeningBrowse Candidates

2ACTIVE JOBS12

3TOTAL CANDIDATES184

4AVG MATCH QUALITY68%

5SHORTLISTED TALENT9

3Candidate Pipeline Stages184 total

4

Match Score Distribution68%5

6Today's Searched5 today

Ahmed S. · Backend Eng.
Mona K. · Data Analyst

Sourcing Files

New Job

Job Title	Status	Total	Short.	Unseen	Created By	Last Accessed	Activity
Senior Engineer	complete	32	3	10	Sara N.	Omar H.	2 hours ago

View

7

- 1 Header buttons "New Job Opening" and "Browse Candidates".
- 2 Four stat cards.
- 3 Candidate Pipeline Stages bar chart.
- 4 Match Score Distribution histogram.
- 5 Today's Searched Candidates list.
- 6 "New Job" shortcut on the Sourcing Files card.
- 7 Sourcing Files table with the per-row "View" button.

What each number means

Item	Definition
Active Jobs	All jobs you ever created (there is no "active" flag; deleted jobs vanish).
Total Candidates	Candidates you own. A person found for two jobs counts once.
Average Match Quality	Average the scores within each sourcing run, then average those per-run averages (every file weighs the same). Shows "No evaluated files yet" until you have scored something.
Shortlisted Talent	Your candidates whose status is Shortlisted.
Pipeline Stages	Counts by status in the order New, Reviewed, Shortlisted, Contacted, Hired, Rejected.
Score Distribution	Histogram of all your match scores in buckets 0-20, 21-40, 41-60, 61-80, 81-100.
Today's Searched	Candidate records <i>created</i> today (server time, UTC on Vercel), newest 8. A person re-found today who already existed is not counted.
Sourcing Files columns	Job Title; Sourcing Status (pending / running / complete / error); Total Candidates newly linked by that run; Shortlisted; Unseen = not yet opened by you from this file; File Created By; Last Accessed By; Last Activity; Action.

Control	What it does	API / route	Notes
New Job Opening	Opens the new-job form.	link to /jobs/new	
Browse Candidates	Opens the job picker.	link to /candidates	
New Job (Sourcing Files card)	Same as New Job Opening.	link to /jobs/new	
View (per file row)	Opens that job's candidate list.	link to /candidates?jobId=&runId=	The list is job-wide, not limited to that run. Opening records an access.
Candidate name (Today's list)	Opens the candidate profile.	link to /candidates/<id>	No jobId, so no Match Score card and it is not marked seen.

Good to know

The table shows the newest 20 runs. A re-run on the same job counts only candidates *newly linked* by that run. If any dashboard query fails, a red banner says "Some dashboard data failed to load. Try refreshing the page."

/jobs

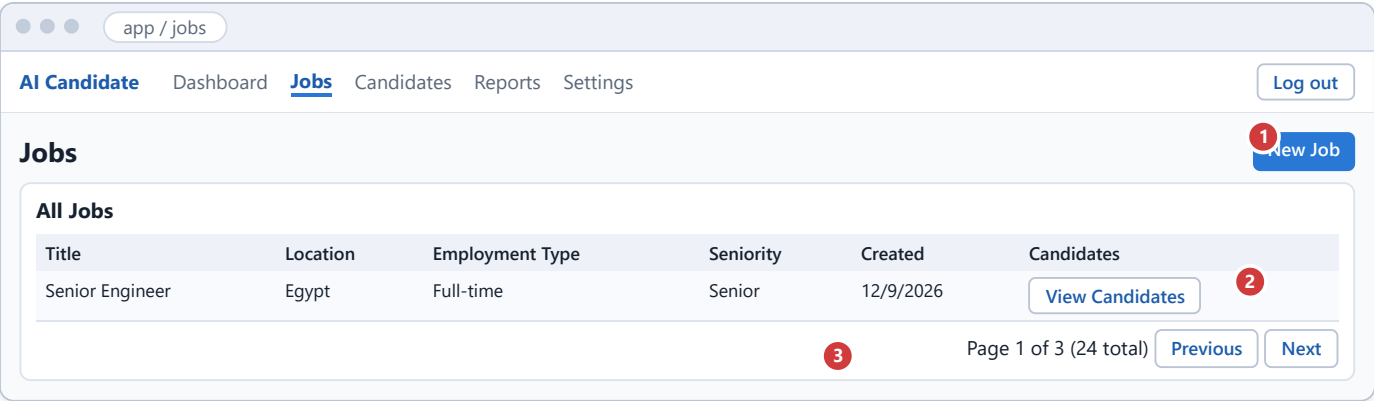
Jobs list

Admin

Manager

User

Lists **your own** jobs only, 10 per page, newest first (managers and admins do not see team jobs here; use the Team page). There is no edit, delete or detail screen for a job on this page.

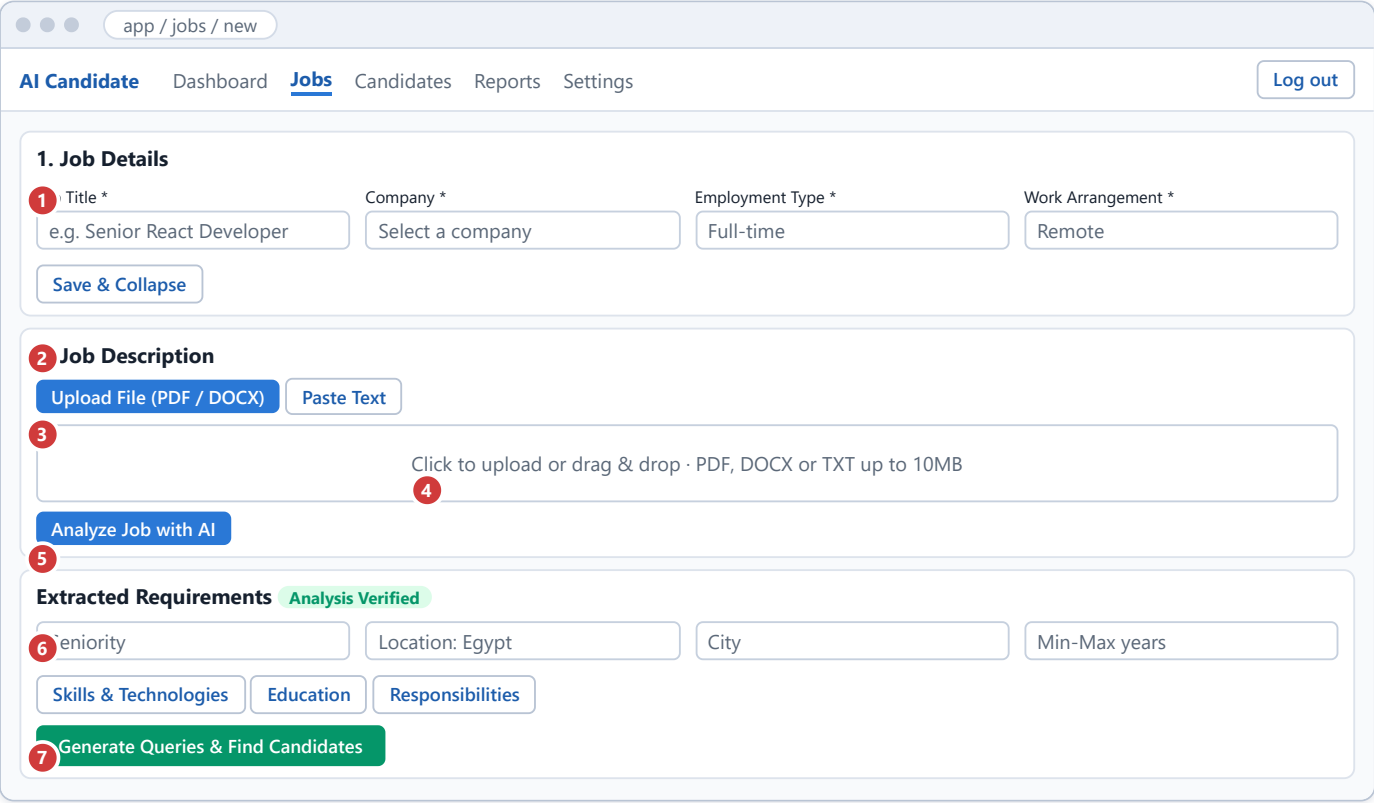


- 1 "New Job" button.
- 2 "View Candidates" link on each row.
- 3 Pagination.

Control	What it does	API / route	Notes
New Job	Opens the new-job form.	link to <code>/jobs/new</code>	
View Candidates	Opens the candidate list for the job.	link to <code>/candidates?</code> <code>jobId=</code>	No runId, so no access is recorded.
Previous / Next	Page through jobs; disabled at the ends. Shows "Page X of Y (N total)".	<code>GET /api/jobs?</code> <code>page=&limit=10</code>	States: "Loading jobs...", error text, or "No jobs yet. Create your first job to start finding candidates."

</jobs/new> **New job and sourcing** [Admin](#) [Manager](#) [User](#)

One long page in three stages: **describe the job**, let AI **extract requirements** you can edit, then **start sourcing**. It is the same for all roles.



- 1 Job Details fields (title, company, employment type, work arrangement; all required).
- 2 Mode toggle: upload a file or paste text.
- 3 Drop zone / text box for the job description.
- 4 "Analyze Job with AI" button.
- 5 Editable role profile (seniority, location, city, employment type, experience range).
- 6 Tabs of editable chip lists (skills, education, responsibilities and keywords).
- 7 "Generate Queries & Find Candidates" starts the search.

Control reference

Control	What it does	API / route	Notes
Job Title *	Text; required (error "Job title is required." after you leave the field). Auto-filled from AI only if empty.	saved as <code>jobs.title</code>	Editing "Job Title" in the requirements editor changes only the AI analysis copy, not this field.
Company *	Dropdown of the eight group companies (G Developments, G Communities, G Lifestyle, G Hotels, G Clubs, G Utilities, G Investments, BuildDora). Shows "Loading companies..." then "Select a company".	GET <code>/api/companies</code>	Companies have no UI; managed in the database.
Employment Type *	Full-time, Part-time, Contract, Internship.	saved with job	AI may prefill it; an AI value outside the four options passes validation but the dropdown shows blank.
Work Arrangement *	Remote, Hybrid, On-site. Never prefilled.	saved with job	
Save & Collapse	Only collapses the card. Nothing is saved.	none	Clicking a card header also toggles it.
Upload File (PDF / DOCX) / Paste Text	Switch between the two input modes (upload is the default).	none	
File drop zone	Choose or drop a PDF, DOCX or TXT. The text is extracted and shown in a scrollable preview with the file name and size.	POST <code>/api/files/extract</code>	Server rejects over 10 MB, other types, or unreadable/password-protected files. Scanned image PDFs return empty text with no explicit message.
Change File / X icon	Re-open the file picker / remove the file and clear the text.	none	
Paste text box	Paste the full job description. Shows a live character count; minimum 50 characters.	none	No maximum.
Analyze Job with AI	Collapses both cards, shows "Analyzing Job Description...", and fills the requirements.	POST <code>/api/jobs/analyze</code>	Disabled under 50 characters. Rate limit 10 AI calls/min. On failure a toast shows and you must reopen the description card to see the inline error.

Control	What it does	API / route	Notes
Role profile fields	Job Title, Seniority Level, Location (only "Egypt"), City (Not specified, Cairo, Alexandria, Giza, Suez), Employment Type, Min / Max Experience (years).	saved in <code>ai_analysis</code> and job columns	City narrows the search location. Min/Max are not validated against each other. Editor's Employment Type is ignored once the Section 1 value is set.
Tabs: Skills & Technologies / Education & Qualifications / Responsibilities & Keywords	Switch between editable lists: Required Skills (green), Preferred Skills (amber), Education, Certifications, Languages, Industries, Responsibilities, Keywords.	none	Each chip is editable inline; X removes it; the input plus Add (or Enter) appends. Blank ignored, duplicates allowed.
<code>Generate Queries & Find Candidates</code>	Runs the whole start-up sequence (see below). Shows "Finding Candidates..." while working.	<code>POST /api/jobs/generate-queries</code> , <code>POST /api/jobs</code> , <code>POST /api/jobs/<id>/search</code> , <code>GET /api/search/<runId>/status</code>	Disabled until the four required Section 1 fields are valid. Rate limits: 10 AI/min, 5 searches/min.
<code>Show Candidates</code> / <code>Close</code>	Buttons in the "Candidate Sourcing Complete!" dialog: open the candidate list for the new job / dismiss.	link to <code>/candidates?jobId=</code>	No confirmation dialogs exist on this page.

What happens when you click "Generate Queries & Find Candidates"

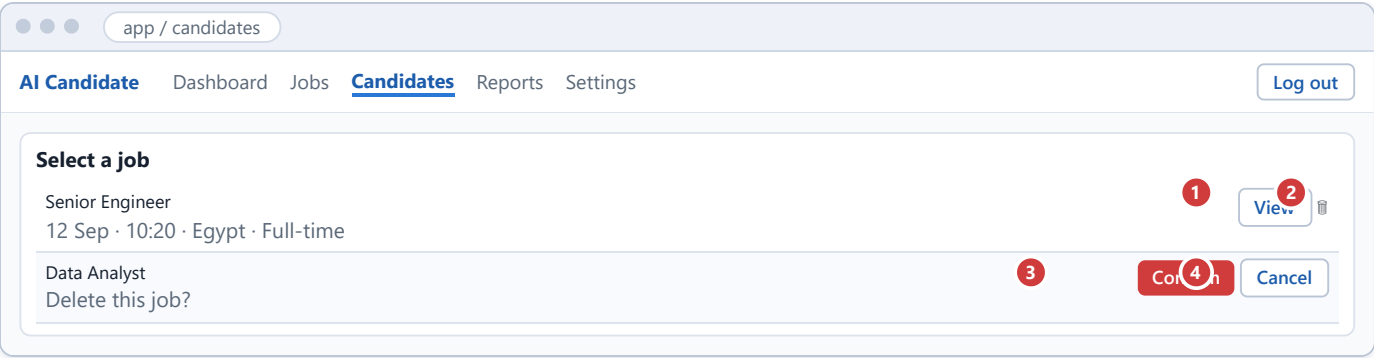
- 1 AI writes 2-4 Google X-ray search queries from the requirements.
- 2 The job is **saved** to your account (before any search starts).
- 3 A sourcing run is created and the search runs in the background; the page gets a 202 reply.
- 4 The page polls the run status every 2 seconds for up to 10 minutes. On completion a dialog shows the number of candidates found. If it is still running after 10 minutes you see "Search is taking longer than expected. Check back shortly." and the search continues on the server.

Wording vs. reality

The progress label "computing AI match scores" and the dialog phrase "identified and evaluated N candidates" are misleading: no scoring has happened yet. Scores appear only after you click "Score Candidates" on the candidates page. Also, if the search fails to start, the job stays saved and clicking again creates a duplicate job. You cannot see or edit the generated queries.

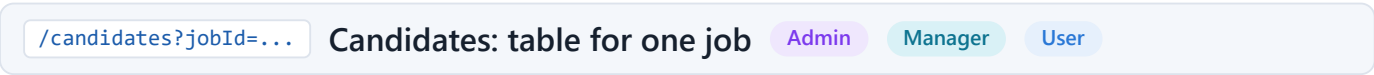
`/candidates` **Candidates: job picker** `Admin` `Manager` `User`

Without a `jobId`, the page shows "Select a job". It lists **only your own jobs, and only the newest 20** (no pager; older jobs are reachable from the Jobs page).

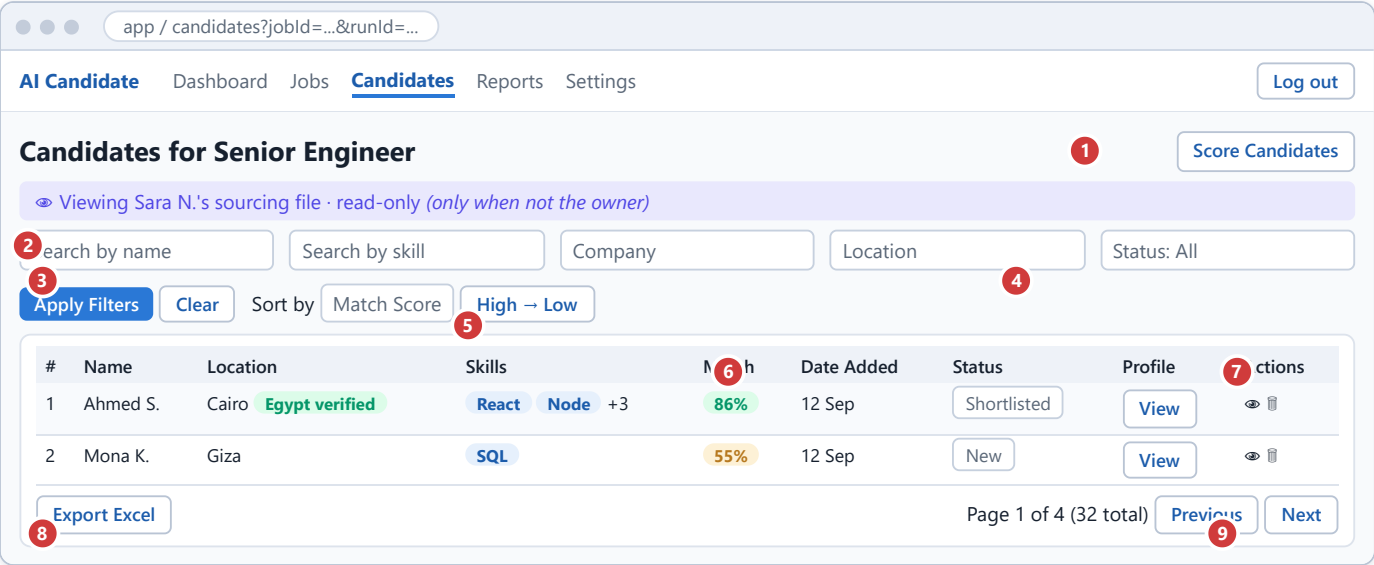


- 1 "View" opens the job's candidate list.
- 2 Trash icon starts an inline delete confirmation.
- 3 "Confirm" deletes the job.
- 4 "Cancel" aborts.

Control	What it does	API / route	Notes
View	Opens the candidate table for that job.	link to <code>/candidates?jobId=</code>	
Trash icon ("Delete <title>")	Replaces the row buttons with "Delete this job?" plus Confirm and Cancel.	none	The only in-app way to delete a job.
Confirm	Deletes the job ("Deleting..." while working). Toast "Job Deleted / Job and its listing removed." or "Delete Failed".	<code>DELETE /api/jobs/<id></code>	Owner only; logs "Job deleted". Candidate records you own are not removed by this.
Cancel	Dismisses the confirmation.	none	



The workhorse screen. Filters, scoring, status changes, deletion and Excel export all live here. When you open *someone else's* job (Manager or Admin), the page becomes **read-only**: a banner reads "Viewing <Owner>'s sourcing file - read-only" and Score, delete and status dropdowns are hidden.



- 1 Score Candidates (hidden for read-only viewers or when no candidates).
- 2 Filter inputs and Status dropdown.
- 3 Apply Filters and Clear buttons.

- 4 Sort dropdown and direction toggle.
- 5 Skills cell: three badges, "+N" expands.
- 6 Match badge (green 70+, amber 40-69, red below 40, blank if unscored).
- 7 Status dropdown per row (badge only for non-owners).
- 8 Export Excel.
- 9 Pagination.

Control	What it does	API / route	Notes
Search by name / Search by skill / Company / Location	Case-insensitive contains filters, combined with AND.	GET /api/jobs/<id>/candidates? name&skill&company&location&status&sort_by&sort_dir&page&limit=10	Typing alone does nothing; Enter does nothing. Click Apply Filters.
Apply Filters	Applies the four text filters and jumps to page 1.	same	
Status filter	"All statuses" or one of New, Reviewed, Shortlisted, Rejected, Contacted, Hired. Applies immediately.	same	
Clear	Resets the five filters (keeps the sort) immediately.	same	
Sort by	Match Score, Experience, Name, Date Added. Applies immediately. Default: Match Score, high to low.	same	Empty values always sort last.
High → Low / Low → High	Toggles sort direction.	same	
Score Candidates	Sends every candidate on the job to AI for scoring ("Scoring..." while working). Toast "Scored N candidates successfully!". Summary "Scored X of Y candidates (Z failed)."	POST /api/jobs/<id>/match	Owner only. Re-scores everyone and overwrites earlier scores. No confirmation. 1 AI rate-limit hit but one OpenAI call per candidate. Runs synchronously, so large lists take a while.
Candidate name / eye icon	Opens the candidate profile with the job context so the Match Score card shows.	link to /candidates/<id>?jobId=	Also marks the candidate as seen for you.
Skills "+N" / "Show less"	Expands or collapses the skills cell.	none	
Status dropdown (row)	Sets New / Reviewed / Shortlisted / Rejected / Contacted / Hired. Toast "Candidate status marked as ...".	PUT /api/candidates/<id>/status	Owner only, no confirmation. Status belongs to the candidate, so it changes for every job the person is linked to.
View (Profile column)	Opens the LinkedIn/source profile in a new tab.	external profile_url	Blank if no URL.
Trash icon, then Confirm / Cancel	Inline "Delete?" confirmation; Confirm deletes the candidate.	DELETE /api/candidates/<id>	Owner only. See warning below: this is a global delete.

Control	What it does	API / route	Notes
Export Excel	Downloads an .xlsx of all rows matching the applied filters and sort (ignores paging). See section 9 for columns.	<code>GET /api/jobs/<id>/export?... </code>	Plain link: an error (e.g. 429) navigates to raw JSON. Visible to read-only viewers too. Unapplied typed filters are not included.
Previous / Next	Page through results, 10 per page. "Page X of Y (N total)".	same list API	Empty: "No candidates match these filters."

Deleting a candidate is permanent and global

The toast says "Candidate removed from this job", but the candidate record is deleted for all jobs, together with their matches, notes, status history and links. There is no undo.

Automatic side effect: when the URL includes `runId`, opening the page records an access on that sourcing file (section 8).

[/candidates/\[id\]](/candidates/[id]) **Candidate profile** [Admin](#) [Manager](#) [User](#)

Everything known about one person. Add `?jobId=` to also see the AI match breakdown for that job (and to mark the candidate as seen). There is no back button; use the browser or the menu.

app / candidates / 3f2a...?jobId=...

[AI Candidate](#) [Dashboard](#) [Jobs](#) [Candidates](#) [Reports](#) [Settings](#) [Log out](#)

Ahmed S. Egypt

Senior Backend Engineer · Acme · Cairo

Experience: 8 yrs · Skills: Node, SQL, AWS · Source: serpapi

[View profile](#)

Match Score

86%

Skills 90% · Experience 85% · Location 100% · Education 70% · Seniority 80%

AI summary text...

Matched requirements · Missing requirements · Strengths · Concerns

Status

Shortlisted

Interviewer Notes

Add a note about this candidate...

[Add Note](#)

12 Sep 10:44 — Called, interested.

- 1 "View profile" external link.
- 2 Match Score card (only with jobId; otherwise absent).
- 3 Status dropdown.
- 4 Notes textbox (owner only).
- 5 "Add Note" button.

Control	What it does	API / route	Notes
View profile	Opens the source profile in a new tab.	external	

Control	What it does	API / route	Notes
Status dropdown	Changes the candidate's status. Non-owners see plain text "<status> - only <owner> can change this".	PUT <code>/api/candidates/<id>/status</code>	The response replaces the page's candidate data, so the Match Score card and edit controls can vanish until you reload.
Note textbox + <button>Add Note</button>	Saves a note ("Saving..." while working) and shows it at the top. Toast "Recruiter note saved to candidate record".	POST <code>/api/candidates/<id>/notes</code>	Owner only; blank disabled. Notes cannot be edited or deleted, and the author is not shown. Non-owners see the list read-only.

Not shown anywhere in the UI: the candidate's status history (recorded by a database trigger) and the Egypt-verified flag. Missing candidates show "Candidate not found."; there is no delete button on this page.

</reports>
Reports
Admin
Manager
User

Four reports with the same controls. What differs is the **scope**, decided on the server from your role: HR User = "My work"; HR Manager = own team; Admin = whole organization or one chosen team. Full report contents are in section 9.

app / reports?type=performance

AI Candidate
Dashboard
Jobs
Candidates
Reports
Settings
Log out

Whole organization · Last 30 days

Team Performance Report

Admin view: every user in the organization.

1

2

Team Performance
Activity
Recruitment Pipeline
Sourcing Quality

Scope
Whole organization
Period
Last 30 days
From
--
To
--
Update report
CSV
Excel
4

MEMBERS
7

JOBS CREATED
17

CANDIDATES SOURCED
466

AVERAGE MATCH
68%

Performance by member

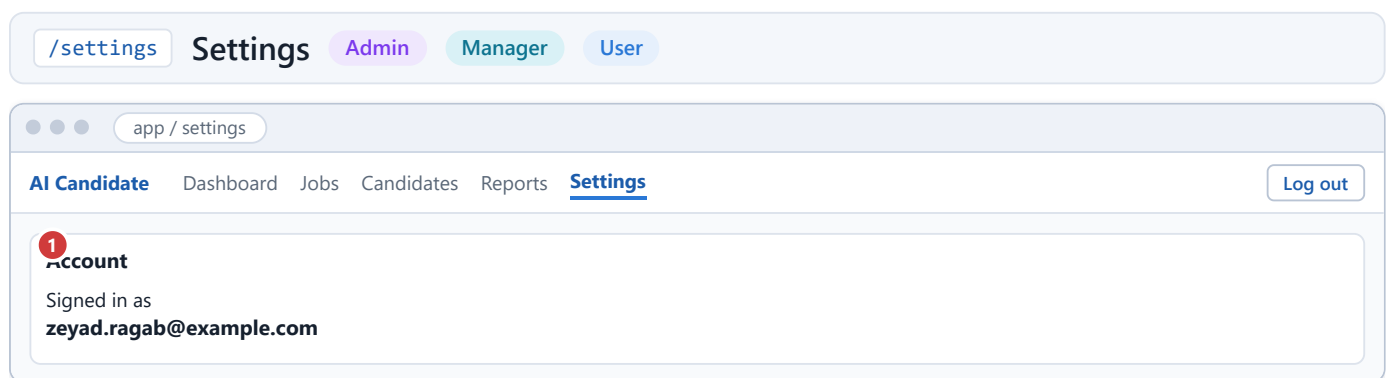
Member	Jobs	Sourcing runs	Candidates	Shortlisted	Avg match
Sara N.	6	7	120	9	74%

- Report type tabs.
- Scope dropdown (admins only).
- Period, From, To and "Update report".
- CSV / Excel export buttons.

Control	What it does	API / route	Notes
Tabs: Team Performance / Activity / Recruitment Pipeline / Sourcing Quality	Switch report; keep the chosen period.	<code>/reports?type=performance activity pipeline quality</code>	Default: performance.
Scope dropdown	"Whole organization" or one team. Admins only.	<code>/reports?teamId=</code>	Managers' <code>teamId</code> is ignored.

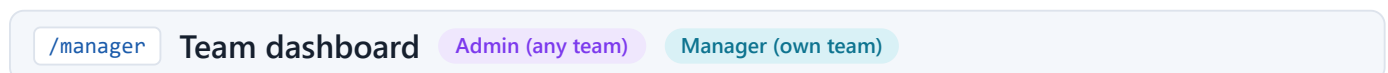
Control	What it does	API / route	Notes
Period dropdown	All time, Today, Last 7 days, Last 30 days (default), Last 90 days, Custom range.	<code>range</code>	
From / To dates	Custom window; entering dates without choosing Custom counts as Custom.	<code>from</code> , <code>to</code>	"To" is inclusive.
<code>Update report</code>	Reloads with the chosen filters.	GET <code>/reports</code>	Viewing writes a "Report viewed" audit entry (deduped for 10 minutes).
<code>CSV</code> / <code>Excel</code>	Downloads the current report.	GET <code>/api/reports?...&format=csv xlsx</code>	Rate limit 20/min. Logs "Report exported".

If a report fails: "This report couldn't be generated. Try again in a moment."



1 The only element: your sign-in email.

No buttons, dropdowns or filters. There is no way to change a password, name or preferences in the app.



A read-only view of a team's output. A Manager is pinned to their own team (the URL `teamId` is ignored). An Admin sees the first team alphabetically and can switch team with a picker or via links on `/admin`. HR Users are redirected to `/dashboard`. Figures are all-time, and everything is read through the viewer's database permissions.

app / manager

AI Candidate
Dashboard
Jobs
Candidates
Reports
Settings
Team
Log out

Team view
Sales Recruiting
Managed by Omar H. · 3 active members. Team members keep ownership of their files.

2
TEAM MEMBERS
3 / 4
TEAM JOBS
17
AVG MATCH QUALITY
68%
SHORTLISTED TALENT
9

3
Team Pipeline
184 total
4
Sourcing Runs
Running 1 · Completed 14
Failed 0 · Unseen by you 22

5
Team Members
6
Sara N.
HR USER
Active 1 · Cand. 120 · Short. 9
Omar H.
TEAM MANAGER
Active 0 · Cand. 64

Team Sourcing Files
14 files
Team member
Everyone
Job title
Any title
Status
Any
Created
All time
From/To
--
Min match %
--
Min cand.
--
Apply
Reset

7
8

Job Title	Status	Cand.	Short.	Unseen	Match	Owned By	Last Accessed By	Last Activity		
Senior Engineer	complete	32	3	10	74%	Sara N.	Omar H.	NOT OWNER	2 h ago	View

9

8
Member Comparison

User	Jobs	Runs	Cand.	Avg Match	Last Login
Sara N.	6	7 / 7	120	74%	1 h ago

9
Team Activity
Sara completed a sourcing run...

- Hero with team name and manager (admins with more than one team also see a "Team" dropdown and "View team" button here).
- Four stat cards.
- Team Pipeline chart.
- Sourcing Runs summary.
- Team Members cards (each links to the member page).
- Filter form for sourcing files.
- "View" button on each sourcing file row.
- Member Comparison table.
- Team Activity feed.

Card definitions

Card / column	Meaning
Team Members	Active / all profiles on the team (includes the manager and inactive people).
Team Jobs	All-time jobs owned by team members.
Sourcing Runs card	Running (pending or running), Completed, Failed, Unseen by you , Contacted and Rejected candidate totals. "Unseen by you" counts candidates <i>you</i> have never opened from the file, not what the owner has seen. It covers only the newest 200 files (500 when filters are on).
Member card	Initials, name, "Team Manager" or role, "Inactive" if applicable, mini-stats Active files / Candidates / Shortlisted, "N files, last active ...", and a colored match badge.

Card / column	Meaning
Team Sourcing Files	One row per sourcing run of any team member, newest first, maximum 200 rows, no sorting, paging or export. Columns: Job Title (with "Created date by starter"), Status, Candidates, Shortlisted, Unseen, Match (average score), Owned By, Last Accessed By (with "Not owner" tag when the last opener is not the owner), Last Activity, Action.
Member Comparison	Per member: Jobs, Runs (completed / total), Candidates, Shortlisted, Contacted, Rejected, Avg Match, Last Login, Last Activity.
Team Activity	Latest 20 recorded actions by team members, including the manager's own.

Control	What it does	API / route	Notes
Team dropdown + View team Admin	Switch to another team. Only shown when there is more than one team.	GET <code>/manager?teamId=</code>	Managers never see it.
Member card (whole card)	Opens that member's page.	link to <code>/manager/team/<id></code>	Also Owned By names and Member Comparison names.
Team member dropdown	Everyone or one member.	<code>member</code> parameter	
Job title	Contains-match on the job title (max 120 characters).	<code>title</code>	
Status	Any, Pending, Running, Complete, Failed.	<code>status</code>	Failed = error.
Created	All time (default), Today, Last 7/30/90 days, Custom range.	<code>range</code>	Uses server time. Filters on the run's creation date.
From / To	Custom dates (YYYY-MM-DD).	<code>from</code> , <code>to</code>	Dates without Custom are treated as Custom.
Min match %	0-100; keeps files whose average score is at least this. Unsourced files drop out.	<code>minMatch</code>	
Min candidates	Keeps files with at least N candidates.	<code>minCandidates</code>	Invalid values are silently ignored.
Apply	Submits the filter form (full page reload).	GET <code>/manager</code>	
Reset	Clears all filters. Appears only when a filter is active.	link to <code>/manager</code>	
View (file row)	Opens the file read-only and records that you accessed it.	link to <code>/candidates?jobId=&runId=</code>	Logs "Opened a teammate's sourcing file" (deduped 30 min). Ownership never changes.

Empty and error states: "You're not assigned to a team yet" (manager without a team), "No teams yet" (admin), "Team unavailable", "No sourcing files match these filters", "No team members yet", and the red banner "Some team data failed to load. Figures below may be incomplete." The page does not refresh itself.

`/manager/team/[userId]`
Team member page
Admin (anyone)
Manager (own team)

A drill-down on one person. Invalid ids and members of other teams give "Page not found". Managers can open their own page. It is entirely read-only: role, team and access changes are made only on `/admin`.

app / manager / team / 9c1e...

AI Candidate
Dashboard
Jobs
Candidates
Reports
Settings
Team
Log out

1 Back to Sales Recruiting

HR User · Sales Recruiting

2 Sara N.

sara.n@example.com · Status: Active · Last login: 1 h ago · Last activity: 20 min ago

JOBS CREATED
6

SOURCING RUNS
7 / 7

AVG MATCH QUALITY
74%

SHORTLISTED
9

3

Candidate Pipeline 120 total

Performance Overview

Active runs · Completed
Failed · Total candidates
Contacted · Rejected

Sourcing Files 7 files

Job Title	Status	Cand.	Short.	Unseen	Match	Last Accessed	Activity	
Senior Engineer	complete	32	3	10	74%	Omar H.	2 h ago	4 View

5 Recently Opened

Data Analyst · 3 h ago

Recent Activity 74% avg match

Sara completed a sourcing run...

- 1 Back link to the team page.
- 2 Profile hero: role, team, email, status, last login, last activity.
- 3 Sourcing files (max 50, no filters, no Owned By column).
- 4 "View" opens the file read-only and records your access.
- 5 Recently Opened (last 8 files this person opened) and Recent Activity (last 25 actions).

Control	What it does	API / route	Notes
Back to <team>	Returns to the team dashboard.	link to <code>/manager</code> (admin: <code>?teamId=</code>)	
View (file row)	Opens the sourcing file read-only.	link to <code>/candidates?jobId=&runId=</code>	Records an access by <i>you</i> .
Recently Opened links	Open a file that this person opened recently (skipped if you cannot see it).	link to <code>/candidates?jobId=&runId=</code>	Clicking records an access by you, not by them.

/admin
Admin dashboard
Admin only

Organization-wide numbers plus every management control. Anyone who is not an active admin is silently redirected to `/dashboard`. Nothing here asks for confirmation, and nobody affected is notified. All performance figures are all-time.

app / admin

AI Candidate
Dashboard
Jobs
Candidates
Reports
Settings
Team
Admin
Log out

System-wide view

Admin Dashboard

Organization-wide sourcing performance across 2 teams and 6 active users.

1
ACTIVE USERS
6 / 7

TOTAL JOBS
17

AVG MATCH QUALITY
68%

SHORTLISTED TALENT
9

Organization Pipeline 466 total

Sourcing Runs

Running · Completed · Failed
Contacted · Rejected

Teams

2
New team name
Add Team

Team	Manager	Members	Jobs	Active Runs	Candidates	Shortlisted	Avg Match
Sales Recruiting	3 Omar ...	3 / 4	17	1	184	9	68%

User Performance

User	Team	Jobs	Runs	Cand.	Short.	Avg Match	Last Login
4 Sara N.	Sales	6	7 / 7	120	9	74%	1 h ago

Access & Invitations 2 requests

name@company.com
HR User
Team
5 Invite

Access requests (2)

new.person@x.com · Tried to sign in 1 h ago
HR User
Team
6 Approve

Pending invites (1)

ali@x.com · HR User · Sales · invited 2 d ago
7 Withdraw

User Management

User	Role	Team	Status	Action
Sara N. sara.n@x.com	HR User	8 Sales	Active	Deactivate

Recent Activity

9 Sara completed a sourcing run for "Senior Engineer"... · 20 min ago

- Hero and four stat cards (Active Users active/all, Total Jobs, Average Match Quality, Shortlisted Talent).
- Add Team form (name field + button).
- Manager dropdown for each team; the team name links to that team's dashboard.
- User Performance table (names link to member pages).
- Invite form: email, role, team, Invite.
- Approve button on each access request.
- Withdraw button on each pending invite.
- User Management: role and team dropdowns, Deactivate / Reactivate.
- Recent Activity feed (newest 20 across the organization).

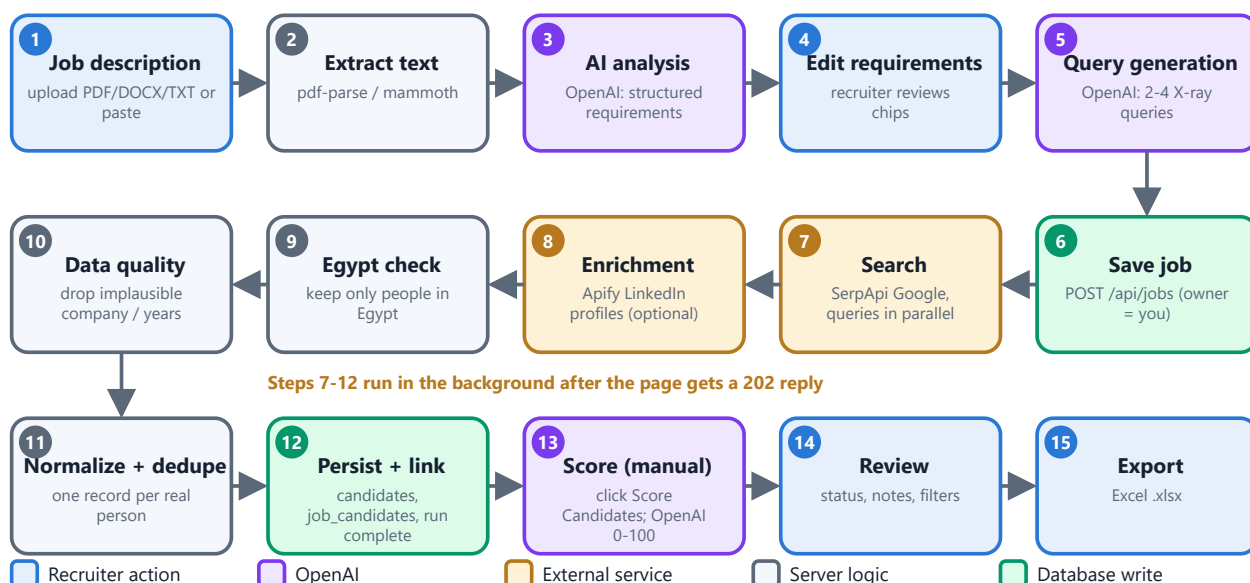
Control	What it does	API / route	Notes
New team name + <button>Add Team</button>	Creates a team. Toast `Created team "<name>".` Field allows 80 characters.	POST /api/teams	No manager picker at creation. Duplicate team names are allowed. Logs "Team created".
Team name link	Opens the team's dashboard in admin view.	link to /manager?teamId=	
Manager dropdown (per team)	Lists "Unassigned" and every <i>active HR Manager</i> . Choosing one makes them the team's manager. Toast "<Name> now manages <Team>." or "<Team> has no manager."	PATCH /api/teams/<id> {managerId}	The chosen manager is moved into that team and removed as manager elsewhere. "Unassigned" only clears the label: the old manager keeps the HR Manager role and team, so they still see the team.
User name link (performance table)	Opens the member page.	link to /manager/team/<id>	
Invite: Email, Role, Team	Email (required), Role (Admin / HR Manager / HR User, default HR User), Team ("No team" or a team; default the first team).	form fields	Team default is fixed at first page render.
<button>Invite</button>	Grants access. Toast "<email> can sign in as <Role>."	POST /api/admin/invites	Existing active user: error "This person already has access." Existing inactive profile: activated at once. Otherwise a pending invite is stored (overwrites an earlier invite for that email). No email is sent.
Access request: Role, Team, <button>Approve</button>	Activates the requester with the chosen role and team. Toast "<Name> can now sign in as <Role>."	POST /api/admin/invites	There is no Reject. To decline, do nothing.
<button>Withdraw</button>	Deletes an unused invite. Toast "Invite for <email> withdrawn."	DELETE /api/admin/invites?email=	No confirmation. Invites never expire. Cannot revoke someone who already signed in.
Role dropdown (per user)	Changes role. Toast "<Name> is now <Role>."	PATCH /api/admin/users/<id> {role}	Disabled on your own row. Demoting a manager un-manages their teams. Making a user HR Manager on a team with no manager makes them its manager.
Team dropdown (per user)	Moves the user ("No team" removes). Toast "Moved <name> to <Team>." / "Removed <name> from their team."	PATCH /api/admin/users/<id> {teamId}	Their existing jobs and candidates follow them; the old team's manager loses sight and the new one gains it.

Control	What it does	API / route	Notes
Deactivate / Reactivate	Toggles access. Toast "Deactivated <name>." / "Reactivated <name>."	PATCH /api/admin/users/<id> > {isActive}	Disabled on your own row; no confirmation. An admin can deactivate another admin, including the last other one.

Failures show a red toast with the server's message (fallback "The change could not be saved."; network problems: "Network error - the change could not be saved."). Each change is a single request, followed by a page refresh. There is no delete user, edit email, password reset, resend invite, team delete or team rename in the UI. The banner "Some admin data failed to load. Figures below may be incomplete." appears when a query fails.

7. The AI sourcing pipeline end to end

From a pasted job description to a shortlist in fifteen steps. Blue steps are yours, purple use OpenAI, amber call outside services. Note the break between step 12 and 13: **searching never scores**. Scoring is a separate, manual click.



Steps 7 to 12 happen in a background task; the browser polls the run's status until it is complete, failed or 10 minutes pass.

Stage by stage

#	Stage	What happens	Limits and behaviour
1-2	Get the text	The file is read in the server: PDF via <code>pdf-parse</code> , DOCX via <code>mammoth</code> , TXT as UTF-8. The type is decided by file extension only.	Max 10 MB (server check). No OCR, so image-only PDFs give empty text. Legacy .doc is unsupported. No rate limit.
3	AI analysis	OpenAI reads the description and returns JSON: job title, seniority, employment type, required and preferred skills, years of experience (min/max), education, certifications, languages, industries, keywords, responsibilities. It is told to use only what the text says.	Min 50 characters. 10 AI calls per minute per user. Location is forced to "Egypt". Up to 5 automatic retries on temporary AI errors.
4	Edit requirements	You correct anything the AI got wrong in the requirements editor.	Edits feed the queries and later scoring.
5	Query generation	OpenAI writes 2-4 Google X-ray queries of the form <code>(site:linkedin.com/in OR site:linkedin.com/pub) ("Title A" OR "Title B") "skill" "Egypt"</code> : 3-6 title synonyms, 1-2 short skills and a quoted location.	Counts against the same 10 AI/min. You cannot see or edit the queries. Queries are stored on the job when the run starts.
6	Save job	The job is written to your account with all fields and the full AI analysis.	Saved before the search. A failed search leaves the job behind.
7	Search (SerpApi)	All queries run in parallel against Google. Country code eg and google.com.eg bias results to Egypt; the optional city becomes the location. Job boards, company pages, agencies and career pages are filtered out.	5 searches per minute per user. About 10 organic results per query, so roughly up to 40 raw results. 15 s timeout, 3 tries per request. If every query fails the run ends "error".
8	Enrichment (Apify)	LinkedIn profile URLs are sent to an Apify actor to fetch real name, headline, company, location, about text, skills, experience years and photo. These values override the thin search snippet.	Optional (needs both env variables). 10 URLs per call, 90 s timeout. If it fails the run continues with search-only data and a note is added to the run's error text.

#	Stage	What happens	Limits and behaviour
9	Egypt verification	Only for Egypt-sourced jobs. If a location exists, a word match on "Egypt", "EG" or any of 27 governorates decides; non-matches are dropped. With no location, AI judges from the headline and summary. Unknown is kept.	Candidates whose location text lacks Egypt or a governorate name (e.g. "Alex" alone) are dropped. Green "Egypt verified" badge appears only when confirmed. AI calls here bypass the rate limiter.
10	Data-quality scrub	Removes implausible values: company names equal to the group's own name variants, and experience years below 0 or above 60.	Values are blanked, not the person.
11	Normalize and dedupe	Maps everything to one shape and merges duplicates. Identity: LinkedIn slug, else profile URL, else name + company. First value wins, skills are unioned.	People without URL, or name+company, are never merged.
12	Persist and link	Finds each person among your existing candidates; existing records only get empty fields filled and skills added, otherwise a new record is inserted with status New. Everyone is linked to the job and this run. The run is marked complete with counts (found, new).	Candidates belong to you globally, not to a job. The run keeps the raw results. Credits used = number of queries (0 in mock mode).
13	Score candidates	You click "Score Candidates". For each candidate OpenAI returns match score plus skills, experience, location, education and seniority scores (0-100), matched and missing requirements, strengths, concerns and a summary.	Manual only. 3 candidates at a time. Re-scores everything each click. There is no weighting formula in code: the overall score is what the model returns. Skills are compared by meaning (JS = JavaScript).
14	Review	Filter, sort, open profiles, set statuses, add notes.	Owner only.
15	Export	Excel download of the filtered list (section 9).	20 exports per minute.

Sourcing run statuses

pending	running	complete
---------	---------	----------

pending created, waiting to start; **running** searching and saving; **complete** finished (may still carry a note in the error field, for example a failed enrichment); **error** zero results plus at least one query error, or an unexpected crash ("Search failed unexpectedly. Please try again."). A run can also be stuck at "running" if the server stops the background task, and nothing cleans it up.

Candidate statuses

Status	Meaning / use
New	Default for every newly found candidate.
Reviewed	A recruiter has looked at the profile.
Shortlisted	Worth pursuing. Counted on dashboards; notifies the team manager.
Contacted	Outreach done.
Hired	Placed. Notifies the team manager. Added late; some pipeline views list it after Contacted.
Rejected	Not pursuing.

Any status can be changed to any other. Each change is stored in a status-history table by a database trigger (not shown in the UI) and written to the activity log.

Rate limits at a glance

Action	Limit (per user unless noted)
AI calls (analyze, generate queries, batch score, single score)	10 per 60 seconds, shared among them; one batch score counts as one hit
Start a search	5 per 60 seconds
Exports (Excel of candidates, report CSV/Excel)	20 per 60 seconds
Failed-login recording	10 per 60 seconds per IP address
Everything else (file extract, jobs CRUD, lists, notes, status, admin routes)	Not limited

Limits are kept in memory of each server instance, so they are approximate on Vercel. Exceeding one returns HTTP 429 "Too many requests. Please slow down and try again shortly." with a Retry-After header.

8. Ownership, access tracking and read-only viewing

Four words describe who touched a sourcing file. They appear as columns on the dashboard and the Team pages, and they are easy to confuse.

Created by

The person who **started the sourcing run** (stored as the run's `created_by_email`). Shown as "File Created By" or "by <starter>". Older runs may have none.

Owned by

The owner of the **job** the run belongs to. Only the owner can change the job, its candidates, scores, statuses and notes. Ownership never transfers, even when someone else opens the file.

Accessed by

Every time someone opens the candidate list with a `runId`, a row is written to the access table. "Last Accessed By" shows the latest row, with a "Not owner" tag on Team pages when the opener is not the owner.

Managed by

The team's manager, shown in the Team hero ("Managed by ...") and the Manager column on `/admin`. Managers can see their team's data because of their *role and team*, not because of this label.

What opening a teammate's file does

- 1 A Manager or Admin clicks **View** on a file (or follows a run notification). The URL is `/candidates?jobId=...&runId=...`.
- 2 The page asks the server to record the access. A row is added every time (also for owners opening their own file).
- 3 If the opener is not the owner and has not opened this run in the last 30 minutes, the activity log also gets "Opened <owner>'s sourcing file".
- 4 The job reports that you cannot edit it, so the page switches to read-only: a banner "Viewing <Owner>'s sourcing file - read-only" appears, Score Candidates and delete buttons vanish, and statuses become plain badges.
- 5 Filters, sorting, pagination, candidate profiles and Excel export still work.

Enforced in three layers

Hidden buttons are only cosmetic. The API also refuses every write from a non-owner with 403 "You can view this job, but only its owner can change it.", and the database's row-level security has no write policy for anyone else. Not even an Admin can edit another person's data.

Other things to know

- **Unseen** is per viewer. A candidate becomes "seen" for you only when *you* open the profile with a job context. A manager's Unseen count says nothing about what the owner has seen.
- Opening via the Jobs page, the picker, or job-scored notifications carries no `runId`, so **no access is recorded**.
- Recently Opened links on a member's page record an access by you, not by the member.
- Opening a file does not create a notification. It does appear in the team Activity feed and the Activity report ("Teammate files opened").
- Managers' and admins' Excel exports of a teammate's job are not logged.
- HR Users cannot open other people's jobs at all (the API returns 404).

9. Reports and exports

The four reports

Report (tab)	Summary tiles	Tables
Team Performance Jobs, runs and outcomes per member	Members, Jobs created, Sourcing runs, Candidates sourced, Shortlisted, Average match	<i>Performance by member:</i> Jobs, Sourcing runs, Completed, Active, Failed, Candidates, Shortlisted, Contacted, Rejected, Avg match, with a Total row. Counts are for items created in the period; candidate statuses are current.
Activity Sign-ins and actions per member	Sign-ins, Failed sign-ins, Sourcing runs, Logged actions, Active members (x / n)	<i>Activity by member:</i> Sign-ins, Failed sign-ins, Job actions, Sourcing runs, Teammate files opened, Candidate actions, Team changes, Reports, Logged actions, Last activity. <i>Actions by type:</i> each action, its events and members, most frequent first. The audit log only began recording in September 2026.
Recruitment Pipeline Where candidates sit now	Total candidates, New, Reviewed, Shortlisted, Contacted, Rejected, Hired	<i>Pipeline by member:</i> Total and each status, plus Progressed % = (Shortlisted + Contacted + Hired) / Total. Only candidates sourced in the period.
Sourcing Quality AI match quality	Average match, Files evaluated (x / y), Strong files (70% or more), Weak files (below 40%)	<i>By member</i> (evaluated files, average, Team average row), <i>by job</i> (owner, files, evaluated, average, best file), <i>by sourcing file</i> (job, owner, status, created, candidates, shortlisted, average; up to 500 files).

Scope and period

Role	Scope
HR User	"My work": yourself only.
HR Manager	Everyone on your team (inactive members shown as "Name (inactive)"). A manager with no team falls back to "My work".
Admin	Whole organization (access-request profiles excluded) or one team, chosen in the Scope dropdown.

Period options: All time, Today, Last 7 days, Last 30 days (default), Last 90 days, Custom range (From/To, inclusive). The window filters items by their *created* date; "last activity" is always all-time. Times use the server's clock.

Report exports

- CSV:** UTF-8 with BOM (opens correctly in Excel). Header lines (title, Scope, Period, Generated), then each section as a title row, header row, data rows and totals. Percent and match columns get a " (%)" suffix. Values starting with `= + - @` are prefixed with an apostrophe to prevent spreadsheet formula injection.
- Excel:** sheet "Overview" (header and summary) plus one sheet per section.
- File name: `<title>-report-<scope>-<YYYY-MM-DD>.csv|xlsx`. Rate limit 20/min. Each export is logged as "Report exported".

Excel export of a job's candidates

From the candidates page (**Export Excel**). One sheet named "Candidates", one row per candidate matching the applied filters, ignoring paging. Filename `candidates-<job-title-slug>-<YYYY-MM-DD>.xlsx`.

#	Column	#	Column	#	Column	#	Column
1	Name	6	Skills	11	Education Score	16	Source
2	Headline	7	Match Score	12	Seniority Score	17	Profile URL
3	Company	8	Skills Score	13	Matched Requirements	18	Status
4	Location	9	Experience Score	14	Missing Requirements	19	Recruiter Notes

#	Column	#	Column	#	Column	#	Column
5	Experience (years)	10	Location Score	15	AI Summary	20	Date Added

Lists are joined with ", "; notes newest first; scores are blank if the candidate has not been scored. Strengths, concerns and the Egypt-verified flag are not exported. A job title in a non-Latin script produces a file name like `candidates--2026-09-29.xlsx`.

10. Activity log and audit trail

Every meaningful action writes one row to the `activity_log` table: who, what, on which record, a readable description and extra details. The log powers the Recent Activity feeds, the Activity report and the manager notifications.

Who can see it

- **HR User** only their own rows. **HR Manager** rows of their team's members. **Admin** all rows.
- Feeds show the newest 20 (admin, team), or 25 on a member page. Descriptions read as "<Actor> <description>" with times such as "2 hours ago".
- There is no screen to search the log or export it.

Immutability

Append-only

The table has no update or delete policy for anyone. Rows can only be added, and an insert must carry the caller's own user id. Failures to write a log entry are recorded in server logs but never block the action itself. Notifications are generated from log rows by a database trigger and only their "read" time can be changed by the recipient.

Every action name

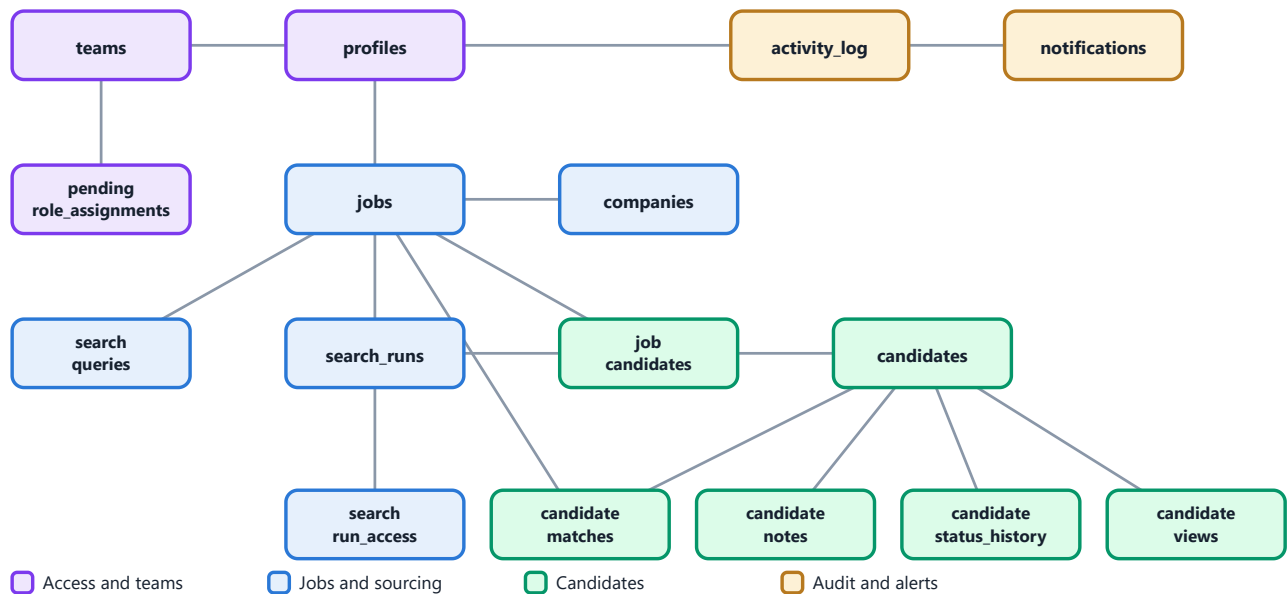
Action	Label shown	Meaning and where it is written
<code>auth.login</code>	Signed in	Successful password login (via the auth events API) or Google login (via the callback; description "Signed in with Google").
<code>auth.logout</code>	Signed out	Log out button.
<code>auth.login_failed</code>	Failed sign-in	Wrong password for an existing account. Recorded by a database function; capped at 10 per account per hour; never reveals whether an email exists.
<code>auth.access_requested</code>	Requested access	An uninvited person signs up. Written by the sign-up trigger; notifies admins.
<code>job.created</code>	Job created	New job saved (Created job "Title").
<code>job.updated</code>	Job updated	Job edited through the API (no screen uses it).
<code>job.deleted</code>	Job deleted	Job removed from the picker.
<code>job.candidates_scored</code>	Candidates scored	Batch scoring finished with at least one candidate scored. Details include counts and strong matches (80%+).
<code>sourcing_run.started</code>	Sourcing run started	A search was queued (query count and provider recorded).
<code>sourcing_run.completed</code>	Sourcing run completed	Search finished ("N candidates, M new").
<code>sourcing_run.failed</code>	Sourcing run failed	Search ended in error.
<code>sourcing_file.accessed</code>	Opened a teammate's sourcing file	A non-owner opened a run; deduped to once per 30 minutes per person and run.
<code>candidate.status_changed</code>	Candidate status changed	Status changed (old and new status in details). No entry if unchanged.
<code>candidate.note_added</code>	Candidate note added	Recruiter note saved.
<code>candidate.deleted</code>	Candidate deleted	Candidate permanently removed.
<code>team.created</code>	Team created	Add Team.
<code>team.updated</code>	Team updated	Manager change or rename.
<code>team.user_updated</code>	User role/team changed	Role, team or active flag changed ("Updated a@b.com: role, team_id"). Deactivation is recorded this way, with <code>is_active</code> in the details.

Action	Label shown	Meaning and where it is written
<code>team.user_invited</code>	User invited	Pending invite stored.
<code>team.access_granted</code>	Access granted	Invite or approval that activated an existing profile.
<code>team.invite_withdrawn</code>	Invite withdrawn	Withdraw button.
<code>report.viewed</code>	Report viewed	Opening a report; identical entries are deduped for 10 minutes.
<code>report.exported</code>	Report exported	CSV or Excel report download.

Not logged: the invited-user sign-up path, automatic manager assignment, opening the admin page, and Excel exports of candidates. Unknown action codes display as the raw code.

11. Data model

Everything lives in one Supabase Postgres database. All 16 tables in the `public` schema have Row Level Security switched on. Below, the key relationships; the base tables (jobs, candidates and so on) predate the migration folder and were created directly in Supabase.



Lines mean "belongs to / references". A job links to many candidates through `job_candidates`; scores live in `candidate_matches` per job and candidate.

Tables

Table	Purpose
<code>profiles</code>	One row per person (id = login id): email, role, team, <code>is_active</code> . Created only by the sign-up trigger. Access to the app equals an active profile.
<code>teams</code>	Team name and manager id. Names are not unique.
<code>pending_role_assignments</code>	Invites for people who have not signed in: lowercase email, role, team, who created it. Consumed on first sign-in.
<code>companies</code>	The eight group companies used in the job form; read-only to the app.
<code>jobs</code>	A role: title, description, Egypt location, optional city, employment type, arrangement, seniority, skills and other lists, experience range, the full AI analysis, company, owner.
<code>search_queries</code>	The Google queries used for a job and the provider.
<code>search_runs</code>	One sourcing run (= sourcing file): status, counts (total results, found, new), credits used, raw results, error text, start and end, who started it.
<code>candidates</code>	A person, owned by one user: name, headline, company, location, profile URL, source, summary, skills, experience years, raw provider data, <code>status</code> , Egypt-verified flag, photo.
<code>job_candidates</code>	Links a candidate to a job (once) and remembers which run first found them.
<code>candidate_matches</code>	AI scoring per job and candidate: overall and five sub-scores, matched / missing requirements, strengths, concerns, summary, run id. One row per pair; re-scoring overwrites it.
<code>candidate_notes</code>	Recruiter notes.
<code>candidate_status_history</code>	Old and new status for every change, filled by a trigger (not displayed).
<code>candidate_views</code>	Which candidate a user has opened for which job; drives "Unseen".

Table	Purpose
<code>search_run_access</code>	Who opened a run's candidate list and when; drives "Last Accessed By".
<code>activity_log</code>	The append-only audit trail (section 10).
<code>notifications</code>	One row per recipient and activity entry, with a read time. Created only by trigger.

Database helper functions

Function	Role
<code>current_profile_role()</code> , <code>current_profile_team_id()</code> , <code>is_admin()</code>	Return the caller's live role, team, or admin flag; return nothing for deactivated users.
<code>managed_user_ids()</code>	Ids of the members of an active HR Manager's team. Powers manager visibility.
<code>handle_new_user</code> (trigger)	Creates the profile on sign-up and applies a pending invite; logs access requests.
<code>notify_on_activity</code> (trigger)	Creates notifications from qualifying log entries.
<code>record_candidate_status_change</code> (trigger)	Writes the status history.
<code>user_performance_stats</code> , <code>activity_summary</code> , <code>sourcing_files</code> , <code>team_sourcing_files</code>	Aggregations behind dashboards and reports; run with the caller's permissions.
<code>profile_last_sign_ins()</code>	Last sign-in times for admins (all), managers (team) or yourself.
<code>record_failed_login(email)</code>	Records failed logins for known accounts; callable before sign-in.

12. Security model

Layers of protection

1. Middleware (route guard)

Protects `/dashboard /jobs /candidates /settings /admin /manager /reports`. No session goes to `/login`; a session without an active profile is signed out and sent to `/login?error=not_allowed`. The home page, login, auth callback and `/api/*` are not covered here.

2. Page checks

Server pages re-check the role: `/admin` redirects non-admins to the dashboard, `/manager` redirects HR Users, and the team member page returns "not found" outside the manager's team.

3. API guards

Every route calls `requireUser` (401 if no user or profile inactive). Admin routes use `requireRole(["admin"])` (403). Writes call the owner check (403). Bodies are validated with zod (400). Some routes are rate limited.

4. Row Level Security

The database itself filters rows for every query, regardless of what the app asks for. It is the last line of defense and cannot be bypassed from the browser.

What RLS allows, by table group

Tables	Owner	HR Manager	Admin
jobs, candidates	Full read and write of own rows	Read rows of own team's members	Read all
job_candidates, candidate_matches, search_queries, search_runs	Full (through own job)	Read via team jobs	Read all
candidate_notes, candidate_status_history	Own	Read team	Read all
search_run_access, candidate_views	Insert own; read own	Read access rows of visible runs	Read all
profiles	Read own	Read own team's	Read and update all
teams	Read own team	Read own team	Read, create, update (no delete)
pending_role_assignments	-	-	Full
companies	Any signed-in user may read; no writes from the app		
activity_log	Insert and read own	Read team's	Read all
notifications	Recipient reads own and may set only the read time; rows are created by trigger		

Deactivation reaches the database

The role helper functions ignore inactive profiles, so a deactivated admin or manager immediately loses elevated data access, not only app access. The original hard-coded email allow-list was removed; only four bootstrap accounts were kept active when access control moved into the database.

Other protections

- **Secrets:** the service-role key and provider keys stay on the server. Errors returned to users are safe generic messages; every response carries an `X-Request-Id` for support.
- **Sign-in abuse:** failed-login recording is rate limited per IP and per account and never confirms whether an email exists.
- **CSV injection:** exported cells starting with `= + - @`, tab or carriage return are neutralised.
- **Export and AI limits** protect cost and stability (section 7). The limiter is per server instance, in memory.

- **No email is ever sent** by the system, including invites; nothing to phish or misdeliver, but people must be told out of band.

Error responses

Status	Message	When
400	First validation message, or "Request body must be valid JSON."	Body fails validation; also file extraction errors (own message, e.g. "File is too large. Maximum size is 10MB.").
401	Unauthorized	Not signed in, or profile missing or deactivated.
403	Forbidden / "You can view this job, but only its owner can change it."	Wrong role, or write on someone else's record.
404	"Job not found.", "Candidate not found.", "Sourcing run not found." ...	Missing, or hidden from you by RLS.
409	"This person already has access." / "This record already exists."	Duplicate invite target, or unique-constraint clash.
429	"Too many requests. Please slow down and try again shortly."	Rate limit hit (Retry-After header).
500	"A database error occurred." / "Something went wrong. Please try again." / route-specific "Failed to ..."	Unexpected failure.
502	"The AI service is currently unavailable...", "The AI returned an unexpected response...", "The search provider is currently unavailable..."	An outside service failed or returned garbage (after retries).
504	"The request took too long. Please try again."	Timeout.

13. Common workflows

A. Recruiter runs a search HR User

- 1 Open **Jobs** → **New Job** (or the dashboard button).
- 2 Fill Job Title, Company, Employment Type, Work Arrangement.
- 3 Upload the job description (PDF, DOCX, TXT) or paste at least 50 characters.
- 4 Click **Analyze Job with AI** and wait for "Requirements successfully extracted".
- 5 Review the requirements: fix seniority, pick a City if the role is city-specific, trim or add skills, education and keywords.
- 6 Click **Generate Queries & Find Candidates**. Do not click again if it fails after "Saving role": the job already exists, so check **Jobs** first.
- 7 Wait for the "Candidate Sourcing Complete!" dialog and click **Show Candidates**.
- 8 Click **Score Candidates** and wait for the toast. Sort by Match Score.
- 9 Open promising people, set statuses (Reviewed, Shortlisted...), add notes.
- 10 Use **Export Excel** to share the shortlist (apply filters first, for example Status = Shortlisted).

B. Manager reviews a teammate's file HR Manager

- 1 Click the bell if you have notifications, or open **Team** in the menu.
- 2 On **Team Sourcing Files** filter by member, status, dates or minimum match.
- 3 Click **View** on the file. Your access is recorded and the page opens read-only.
- 4 Sort by Match Score, open candidates with the eye icon to read scores, strengths, concerns and notes.
- 5 Use **Export Excel** if you need a copy.
- 6 To give feedback or ask for changes, talk to the owner: you cannot change statuses, notes or scores.
- 7 For a broader view use **Team** → **Member page** and **Reports** (team scope).

C. Admin onboards a person Admin

- 1 Open **Admin** → **Access & Invitations**.
- 2 Enter the person's exact work email, pick Role and Team (pick a team first if needed; see workflow D).
- 3 Click **Invite**. A green toast confirms.
- 4 Tell the person yourself to open the app and sign up (email and password, or Google) with that exact email. Nothing is emailed.
- 5 They confirm their email if using a password, then log in. They arrive on the dashboard with the role and team you chose.
- 6 If they signed in before you invited them, they are in **Access requests**: choose role and team and click **Approve** (or invite them, which activates them at once).
- 7 To remove access later, use **Deactivate** in User Management.

D. Admin creates a team and assigns a manager Admin

- 1 In the **Teams** card type the name next to "New team name" and click **Add Team**.
- 2 Make sure the future manager exists with the role HR Manager and is active (Invite as HR Manager, or change their role in User Management).
- 3 In the Teams table open the **Manager** dropdown for the new team and pick them. They are moved into the team automatically and removed as manager of any other.
- 4 Move the team's recruiters into it using the **Team** dropdown in User Management. Their existing work moves with them.
- 5 Click the team name to open the team dashboard and check members, then confirm the manager sees a Team link and the bell.

14. Known limitations and gotchas

An honest list of behaviours a new owner should know about. None stop the system from working, but each can surprise people.

Sourcing and scoring

Gotcha	Details
Search does not score	The UI says "computing AI match scores" and "evaluated N candidates", but scores exist only after clicking Score Candidates. Dashboards show "No evaluated files yet" until then.
Job is saved before the search	If starting the search fails (for example the 5/min limit), the job stays and clicking again creates a duplicate job.
Queries are invisible	Generated queries are stored but never shown, and cannot be edited. The <code>SearchQueries</code> editor component exists but is unused.
Score has no formula	The overall match score is whatever the AI returns. A fractional score would fail to save that candidate (reported as a failure).
Score button re-scores everything	No confirmation, overwrites earlier scores, costs one AI call per candidate and runs synchronously with no time limit configured.
Non-durable background search	Runs after the HTTP reply with no retry. If the server stops it, the run can stay "running" forever; nothing cleans it up. The page stops watching after 10 minutes.
Egypt filter is text-based	Candidates whose location lacks "Egypt" or a governorate name (e.g. "Alex") are dropped.
Default search provider is mock	Unless <code>SEARCH_PROVIDER=serpapi</code> , results are 8 fixture people. <code>serper</code> throws "not implemented".
Complete runs can carry errors	A "complete" run may hold a note (failed enrichment, link errors) that the UI does not display.
Employment Type / Title duplicated	The requirements editor's copies of these are ignored for the saved job once the Job Details section is filled.
Scanned PDFs	Produce empty text; Analyze stays disabled with no explanation. The 10 MB check is server-side only, and hosting limits may reject large uploads earlier.

Candidates and data

Gotcha	Details
Candidate delete is global	Deleting removes the candidate from every job, with notes, history and matches, though the toast says "removed from this job".
Status is global	A candidate's status is shared across all jobs they are linked to.
No confirmations	Status changes, Score Candidates, Approve, Deactivate, Withdraw, role and team changes and Log out all act on first click. Only deleting a job or candidate asks.
Picker shows 20 jobs	The Candidates job picker lists only your 20 newest jobs and has no pager; use the Jobs page for older ones.
Dashboard "today" links	Candidate links in "Today's Searched Candidates" open the profile without job context (no Match card, not marked seen).
Export is a plain link	Errors (like a 429) navigate to raw JSON. Filters typed but not applied are not exported.
Status change on profile	Can hide the Match Score card and edit controls until reload.
Notes are permanent	Cannot be edited, deleted, and do not show the author.
Average match differs	The average excludes scores without a run id, while the distribution chart includes all scores.
Shortlisted counts	Dashboard shortlisted counts ignore Hired and Contacted.

Access and administration

Gotcha	Details
No reject for access requests	Admins can only Approve. Unwanted requests stay listed forever.
No emails or notices	Invites, approvals, role changes and deactivations are not communicated to the person.
Deactivated lookalike	A deactivated HR User with no team is shown as an access request.
No last-admin guard	You cannot demote or deactivate yourself, but you can do it to another admin, even the last other one.
Team management is thin	No rename or delete team in the UI; duplicate team names are allowed; Add Team has no manager picker; "Unassigned" keeps the old manager's team and permissions.
Multi-step changes are not atomic	User and team updates run several statements; a failure midway can leave partial changes, and creating a team with an invalid manager returns an error but leaves the team.
Invite defaults	The Team dropdown's default is fixed when the page first renders; teams created later require a reload. Invites never expire; a mistyped email sits until withdrawn.
Sign-in redirect	The <code>redirectTo</code> set by the route guard is ignored by password login; you always land on the dashboard.
Settings are empty	Only shows your email. No password change or profile editing.
Companies have no UI	Changed only in the database.

Platform

Gotcha	Details
In-memory rate limiter	Each server instance counts separately, so limits are soft on a serverless host and reset on restart. Admin routes are not limited at all.
Time zones	"Today" and report windows use the server clock (UTC on Vercel), not the viewer's.
Team dashboards are snapshots	No auto-refresh; caps of 200 files (500 with filters) apply to team KPIs, 20 items to activity feeds and notifications.
Manager sees only their team	A manager without a team, or an inactive one, sees nothing of the team.

15. Glossary

Term	Meaning
Access request	An inactive profile created when an uninvited person signs up; waits for an admin to approve.
Active / Inactive	Whether a profile may use the app. Inactive users are blocked everywhere.
Admin	Highest role: manages people and teams, sees the whole organization, cannot edit others' sourcing data.
AI analysis	Structured requirements OpenAI extracts from a job description.
Apify	Service that fetches full LinkedIn profile details from URLs.
Bell	Notification dropdown for Admins and HR Managers.
Candidate	A person found by a search, owned by one user.
Dedupe	Merging records that describe the same person.
Egypt verified	Green badge: the candidate's location was confirmed to be in Egypt.
File / Sourcing file	A single sourcing run for a job.
HR Manager	Leader of a team; read-only visibility of the team's work.
HR User	Recruiter; sees only own work.
Invite / Pending invite	A stored role and team for an email that has not signed in yet.
Job	A role being hired for, owned by its creator.
Match score	AI rating 0-100 of how well a candidate fits a specific job. Green 70+, amber 40-69, red below 40; 80+ is a "strong match" for notifications.
Owner	The user who created a job or candidate; the only one who can change it.
Read-only mode	What a Manager or Admin sees when opening someone else's file.
RLS	Row Level Security: database rules that decide which rows each user can read or write.
Sourcing run	One execution of the search-and-collect process for a job.
SerpApi	Service that runs Google searches and returns the results.
Strong match	A match score of 80% or higher.
Team	A named group of users with at most one recorded manager.
Unseen	Candidates in a file that you have not opened (per viewer).
X-ray search	A Google query limited to a site (here LinkedIn profile URLs) with title and skill keywords.

End of the System Guide.